IFT2830 Finals Cheatsheet — Aide-Mémoire Examen Final

Cours: IFT2830 - Sécurité des systèmes informatiques
Professeur: Abdeltouab Belbekkouche
Session: Hiver 2026 (H26)
Date de création: 27 avril 2026

Table des Matières

1. CIA Triad & Security Fundamentals
2. Risk Analysis & Governance
3. Cryptography Fundamentals
4. Symmetric Encryption
5. Asymmetric Encryption
6. Digital Certificates & PKI
7. Network Security
8. Attack Lifecycle & Techniques
9. Application Security
10. Quick Reference Tables

CIA Triad & Security Fundamentals

CIA Triad — Triade CIA

Propriété	Définition	Objectif	Attaque Exemple	Défense Exemple
Confidentialité (C)	Information accessible uniquement aux personnes autorisées	Empêcher divulgation non autorisée	Écoute réseau, vol de données	Chiffrement (AES, RSA), contrôle d'accès
Intégrité (I)	Information non modifiée, complète, précise	Empêcher modification non autorisée	Modification données, corruption fichier	Hash (SHA-256), signatures numériques, MAC
Disponibilité (D)	Information accessible quand nécessaire	Empêcher interruption service	DoS/DDoS, ransomware, panne	Redondance, sauvegardes, DDoS mitigation

French terms:

- Confidentialité = Confidentiality
- Intégrité = Integrity
- Disponibilité = Availability

Extended CIA Properties

Propriété	Définition	Contrôle
Authenticité	Preuve identité légitime	Authentification multi-facteur, certificats
Non-répudiation	Impossible nier action	Signatures numériques, logs, timestamps
Traçabilité	Audit trail des actions	Logs centralisés, SIEM
Imputabilité	Attribution action à personne	User ID, audit logs

Security Principles (Summary)

```
Defense-in-Depth (Défense en profondeur):
  - Multiple layers (physical, network, application, data)
  - If one layer fails, others protect

Least Privilege (Moindre privilège):
  - Minimum permissions needed for task
  - Reduce attack surface

Fail-Safe Defaults (Défaillance sécurisée):
  - Default deny (whitelist, not blacklist)
  - Explicit allow only

Separation of Duties (Séparation des tâches):
  - No single person controls entire critical process
  - Prevents fraud and errors
```

Risk Analysis & Governance

Risk Formula

```
R = P × I

R = Risque (Risk)
P = Probabilité d'occurrence (Probability)
I = Impact (gravité) (Impact/Severity)
```

Example:

```
Attack: SQL injection on e-commerce site
Probability: 70% (CVSS score 7.0, known vulnerability)
Impact: 9/10 (customer data breach, 100K records)
Risk = 0.7 × 9 = 6.3 (HIGH risk)
```

Risk Treatment Strategies

Stratégie	Action	Quand utiliser
Évitement	Éliminer risque (stop activité)	Risque trop élevé, alternatives existent
Réduction	Mitigation (contrôles)	Risque gérable avec contrôles
Transfert	Assurance, externalisation	Risque financier, expertise externe
Acceptation	Accepter résiduel	Risque faible, coût mitigation > risque

Core Definitions

Terme	Définition	Exemple
Actif	Ressource de valeur	Base données clients, serveur Web
Menace	Cause potentielle incident	Attaquant, malware, incendie
Vulnérabilité	Faiblesse exploitable	CVE-2021-44228 (Log4Shell), port ouvert
Impact	Conséquence si matérialisé	Perte données, downtime, amende GDPR
Contrôle	Mesure réduction risque	Firewall, IDS, formation, politique

Governance Framework — Three Axes

Axe Stratégique

```
Niveau: Direction (C-suite, CISO)
Horizon: Long terme (3-5 ans)
Responsabilité: Vision, politique, budget
Livrables:
  - Politique sécurité générale
  - Stratégie cybersécurité
  - Budget annuel sécurité
  - Business continuity plan (BCP)
```

Axe Tactique

```
Niveau: Management intermédiaire
Horizon: Moyen terme (1 an)
Responsabilité: Plans, standards, procédures
Livrables:
  - Standards techniques (chiffrement AES-256, MFA)
  - Procédures réponse incident
  - KPI sécurité (SLA, métriques)
  - Formation sensibilisation
```

Axe Opérationnel

```
Niveau: Équipes techniques
Horizon: Court terme (quotidien)
Responsabilité: Exécution, surveillance, réponse
Livrables:
  - Configuration firewall
  - Monitoring SIEM
  - Patch management
  - Incident response (IR)
```

8 Governance Principles

Principe	Description
Vocabulaire	Terminologie commune (CIA, risque, vulnérabilité)
Volonté directoriale	Support top management (budget, ressources)
Proportionnalité	Contrôles proportionnels à risque (pas over-engineering)
Cohérence	Politiques alignées entre départements

Simplicité	Politiques claires, compréhensibles, applicables
Dynamicité	Révision régulière (menaces évoluent)
Continuité	Plan continuité activité (BCP/DRP)
Évaluation	Audits, métriques, amélioration continue

Cryptography Fundamentals

Core Concepts

Concept	Définition	Objectif Sécurité
Chiffrement	Rendre données illisibles	Confidentialité
Hachage	Empreinte unidirectionnelle	Intégrité
Signature numérique	Preuve authenticité	Authenticité, Non-répudiation, Intégrité
MAC	Message Authentication Code	Intégrité, Authenticité

French terms:

- Chiffrement = Encryption
- Déchiffrement = Decryption
- Texte en clair = Plaintext
- Cryptogramme = Ciphertext
- Clé = Key

Cryptographic Primitives Comparison

Primitive	Entrée	Sortie	Réversible?	Clé?	Use Case
Hash	Données	Digest fixe	Non (one-way)	Non	Intégrité, mots de passe
Symmetric	Plaintext	Ciphertext	Oui (avec clé)	Oui (1 clé)	Confidentialité, bulk data
Asymmetric	Plaintext	Ciphertext	Oui (avec clé)	Oui (2 clés)	Key exchange, signatures
MAC	Message + Key	Tag	Non	Oui (1 clé)	Intégrité, authenticité

Kerckhoffs's Principle

```
"La sécurité d'un système de chiffrement ne doit reposer que sur le secret de la clé."

Translation: Security must rely only on key secrecy, not algorithm secrecy.

Implication:
  ✓ Algorithm can be public (peer-reviewed, battle-tested)
  ✗ Security through obscurity (hiding algorithm) is BAD
```

Symmetric Encryption

Stream vs Block Ciphers

Aspect	Stream Cipher	Block Cipher
Unité traitement	1 bit ou 1 byte	Blocs fixes (64, 128, 256 bits)
Vitesse	Très rapide (petit données)	Optimisé données volumineuses
Use case	Streaming (voix, vidéo)	Fichiers, disques, réseau
Padding	Non requis	Requis si taille ≠ multiple bloc
Exemples	RC4, ChaCha20, Salsa20	AES, DES, 3DES, Blowfish

French terms: *Chiffrement de flux* (stream cipher), *Chiffrement par bloc* (block cipher)

Common Symmetric Algorithms

Algorithm	Type	Key Size	Block Size	Status	Notes
DES	Block	56 bits	64 bits	❌ Obsolète	Cassé (brute force 1999)
3DES (Triple DES)	Block	112/168 bits	64 bits	⚠️ Déprécié	NIST phase-out 2023, remplacer par AES
AES-128	Block	128 bits	128 bits	✅ Bon	Standard actuel
AES-256	Block	256 bits	128 bits	✅ Excellent	Top secret, long-terme

RC4	Stream	40-2048 bits	N/A	❌ Cassé	WEP vulnérable, ne pas utiliser
ChaCha20	Stream	256 bits	N/A	✅ Excellent	Modern, TLS 1.3, mobile
Blowfish	Block	32-448 bits	64 bits	⚠️ Obsolète	64-bit blocks vulnérables (Birthday attack)
IDEA	Block	128 bits	64 bits	⚠️ Rare	Utilisé PGP anciennement

Block Cipher Modes of Operation

Mode	Chiffrement	Parallélisable?	Padding?	Sécurité	Use Case
ECB	C[i] = E(P[i])	✅ Oui	✅ Oui	❌ INSÉCURE	**JAMAIS utiliser** (patterns leak)
CBC	C[i] = E(P[i] ⊕ C[i-1])	❌ Non (enc) / ✅ Oui (dec)	✅ Oui	⚠️ Bon (avec MAC)	Legacy, file encryption + MAC
CTR	C[i] = P[i] ⊕ E(nonce||counter)	✅ Oui	❌ Non	✅ Bon	Disk encryption, parallelizable
GCM	CTR + GMAC	✅ Oui	❌ Non	✅ Excellent (AEAD)	**TLS 1.3, modern protocols**

Recommendation: Use **AES-256-GCM** for new systems (authenticated encryption).

French term: *Mode de chiffrement*

Classical Ciphers (Historical)

Type	Exemple	Mécanisme	Faiblesse
Substitution mono-alphabétique	César (shift by 3)	Remplacer lettres	Analyse fréquence
Substitution homo-alphabétique	Playfair	Lettre → plusieurs représentations	Complexe mais cassable
Transposition	Columnar	Réarrange lettres (ordre)	Analyse patterns

---

Asymmetric Encryption

Key Concept: Public/Private Key Pairs

```
Paire de clés = (Clé publique, Clé privée)

Clé publique:
  - Partagée ouvertement
  - Utilisée par AUTRES pour chiffrer → VOUS
  - Utilisée par AUTRES pour vérifier signature DE VOUS

Clé privée:
  - GARDÉE SECRÈTE
  - Utilisée par VOUS pour déchiffrer
  - Utilisée par VOUS pour signer

Relation mathématique: Lien trapdoor (facile → difficile ←)
```

French terms: *Clé publique* (public key), *Clé privée* (private key), *Paire de clés* (key pair)

RSA Algorithm

Key Generation (Génération clé):

```
1. Choisir deux nombres premiers: p, q
2. Calculer n = p × q (modulus)
3. Calculer φ(n) = (p - 1) × (q - 1)  (Euler's totient)
4. Choisir e tel que gcd(e, φ(n)) = 1  (exposant public, souvent e=65537)
5. Calculer d tel que (e × d) mod φ(n) = 1  (exposant privé)

Clé publique: (n, e)
Clé privée: (n, d)
Détruire: p, q, φ(n)
```

Encryption (Chiffrement):

```
C = M^e mod n
```

Decryption (Déchiffrement):

```
M = C^d mod n
```

Example (p=7, q=19):

```
n = 7 × 19 = 133
φ(n) = 6 × 18 = 108
e = 5  (gcd(5, 108) = 1)
d = 65  (5 × 65 mod 108 = 1)

Public key: (133, 5)
Private key: (133, 65)

Encrypt M=42:
  C = 42^5 mod 133 = 87

Decrypt C=87:
  M = 87^65 mod 133 = 42 ✓
```

Digital Signatures — 5 Steps

```
Processus signature numérique:

1. Résumé (Hash):
   Hash = SHA-256(Message)

2. Chiffrement résumé (Sign with private key):
   Signature = Hash^d mod n

3. Envoi (Message + Signature):
   Envoyer: (Message, Signature)

4. Résumé message reçu (Recipient hashes):
   Hash_received = SHA-256(Message)

5. Vérification (Verify with public key):
   Hash_decrypted = Signature^e mod n

   Si Hash_received == Hash_decrypted:
     ✓ Signature valide (authentique, intègre, non-répudiation)
   Sinon:
     ✗ Signature invalide (tampered ou forgé)
```

What signature proves:

- ✅ **Authenticité:** Message vient du détenteur clé privée
- ✅ **Intégrité:** Message non modifié (hash match)

- ✅ **Non-répudiation:** Signataire ne peut nier avoir signé

What signature does NOT prove:

- ❌ **Confidentialité:** Message envoyé en clair (chiffrer séparément si nécessaire)

Asymmetric Algorithms Comparison

Algorithm	Type	Security Basis	Key Size	Status	Speed	Quantum Resistant?
RSA	General purpose	Factorization	2048-4096 bits	✅ Current	Slow	❌ No (Shor's algo)
ECC	Modern alternative	ECDLP	256-521 bits	✅ Modern	Fast (10x)	❌ No (Shor's algo)
NTRUEncrypt	Post-quantum	Lattice (SVP)	Moderate	🔄 Emerging	Fast	✅ Yes
CRYSTALS-Kyber	Post-quantum (NIST)	Lattice	Moderate	🔄 Standard 2024	Fast	✅ Yes

Key Size Equivalence:

Security Level	RSA	ECC	Symmetric Equivalent
80-bit	1024	160	DES (56) → 3DES (112)
112-bit	2048	224	3DES (112)
128-bit	3072	256	AES-128
192-bit	7680	384	AES-192
256-bit	15360	521	AES-256

Recommendation 2026:

- **New systems:** ECC-256 (faster) OR RSA-3072 (compatibility)
- **Long-term (20+ years):** Start migrating to post-quantum (CRYSTALS-Kyber)

Hybrid Encryption (RSA + AES)

```
Problem: RSA is slow (can't encrypt large files)
Solution: Hybrid encryption (used in TLS, PGP, S/MIME)

Process:
  1. Generate random AES key (32 bytes)
  2. Encrypt data with AES-256-GCM (fast)
  3. Encrypt AES key with RSA public key (slow but small)
  4. Send: Encrypted_data + Encrypted_AES_key

Recipient:
  1. Decrypt AES key with RSA private key
  2. Decrypt data with AES key

Result: Fast symmetric encryption + secure key exchange
```

Digital Certificates & PKI

Certificate Structure (X.509)

```
Certificat numérique contient:
  - Identité (CN, O, L, ST, C)
  - Clé publique
  - Période validité (Not Before, Not After)
  - Émetteur (CA qui a signé)
  - Extensions (SAN, Key Usage, EKU)
  - Signature CA (sur tous champs ci-dessus)
```

French term: *Certificat numérique*

Certificate Classes — Validation Levels

Classe	Nom	Validation	Temps	Use Case	Organisation visible?
Class 1	Email	Email ownership	Minutes	S/MIME personnel	❌ Non
Class 2	Individual	Soft identity	Hours	Signature code personnel	❌ Non
Class 3	DV (Domain Validation)	Domain ownership	Minutes	90% websites HTTPS	❌ Non

Class 4	OV (Organization Val.)	Domain + Org	1-3 days	Corporate sites	✅ Oui
Class 5	EV (Extended Val.)	Highest rigor	1-2 weeks	Banks, financial	✅ Oui (deprecated UI)

Special types:

- **SSL EV:** Class 5 pour HTTPS
- **Dual-Key:** Two key pairs (encryption + signing)
- **Dual-Sided (Mutual TLS):** Client AND server certificates

PKI Components

Composant	Rôle	Responsabilité
CA (Autorité Certification)	Signer certificats	Émettre, maintenir sécurité clé privée, CPS
RA (Autorité Enregistrement)	Vérifier identités	Valider documents, front-end CA
CRL (Liste Révocation)	Publier certificats révoqués	Liste numéros série révoqués, signée CA
CR (Répertoire Certificats)	Base données publique	LDAP, HTTP, certificats émis
End Entity (Entité finale)	Détenteur certificat	Générer clé, CSR, protéger clé privée
Relying Party	Vérificateur	Valider signature, validité, révocation

French terms: *Autorité de Certification (AC)*, *Autorité d'Enregistrement (AE)*, *Liste de Révocation de Certificats (LCR)*

PKCS Standards (Quick Reference)

Standard	Purpose	File Format	Use Case
PKCS #1	RSA crypto	.pem, .der	RSA keys, padding (OAEP)
PKCS #3	Diffie-Hellman	N/A	DH key exchange
PKCS #5	Password-based crypto	N/A	PBKDF2, encrypted keys
PKCS #7	CMS (Cryptographic Message)	.p7b, .p7s	S/MIME, code signing
PKCS #8	Private key format	.pem	Private key storage

PKCS #10	CSR format	.csr	Certificate request
PKCS #11	Hardware token API	N/A	HSM, smart card
PKCS #12	Certificate bundle	.p12, .pfx	Cert + private key (password)

Trust Models

Modèle	Description	Avantage	Inconvénient	Use Case
Confiance Directe	Échange clés en personne	Maximum trust	Ne scale pas	Petits groupes
Tiers de Confiance	Trust CA	Scalable	Single point of failure	Internet PKI
Hiérarchique	Arbre Root→Intermediate→End	Root offline sécurisé	Chaîne complexe	Enterprise PKI
Distribuée (Web of Trust)	Utilisateurs signent clés	Décentralisé	Complexe, ne scale pas	PGP/GPG
Passerelle (Bridge)	Connect PKI indépendants	Inter-organisation	Complexe	Gov PKI, B2B

Certificate Revocation

CRL (Certificate Revocation List):

```
Pros: Offline-capable, simple
Cons: Large files (MB), infrequent updates (24-48h), privacy leak

Format: List of serial numbers + revocation date + reason
```

OCSP (Online Certificate Status Protocol):

```
Pros: Real-time, small response (~1KB)
Cons: Network query (slow), privacy leak (CA sees queries)

OCSP Stapling: Server caches OCSP response, sends with cert (faster, private)
```

Modern Security:

- **Certificate Transparency (CT):** Public logs, monitor unauthorized certs
- **CAA DNS records:** Restrict which CAs can issue certs for domain

- **Certificate Pinning:** App hardcodes expected cert/key (mobile security)

Network Security

DoS vs DDoS

Aspect	DoS	DDoS
Sources	Une seule source	Multiple sources (botnet)
Volume	Limité (bande passante attaquant)	Massif (agrégat botnet)
Difficulté	Facile (script kiddie)	Complex (C&C infrastructure)
Détection	Facile (bloquer IP)	Difficile (IPs distribuées)
Mitigation	Firewall simple	DDoS mitigation service (Cloudflare, Akamai)

French terms: *Déni de service* (DoS), *Déni de service distribué* (DDoS)

Common DoS/DDoS Attacks

SYN Flood

```
Mécanisme:
  1. Attaquant envoie SYN packets (spoofed source IP)
  2. Serveur répond SYN-ACK, alloue ressources (half-open connection)
  3. Attaquant n'envoie pas ACK final
  4. Serveur épuise connection table

Défense:
  - SYN cookies (stateless handshake validation)
  - Rate limiting (max SYN/sec per IP)
  - Increase backlog queue size
```

Amplification Attacks

Protocol	Amplification Factor	Query Size	Response Size	Défense
DNS	50x - 100x	60 bytes	3000+ bytes	Rate limiting, DNSSEC
NTP	556x	234 bytes	130,000 bytes	Disable monlist command
Memcached	51,000x	15 bytes	750,000 bytes	Firewall UDP 11211

SSDP	30x	Small	Large	Disable UPnP externally

Mécanisme:

```
1. Attaquant envoie requête à serveur vulnérable
2. Source IP spoofée = IP victime
3. Serveur répond à victime avec réponse amplifiée
4. Victime reçoit trafic massif (facteur 50-51,000×)
```

Reflection Attacks

```
Similaire amplification mais:
  - Utilise serveurs légitimes comme "miroirs"
  - Cache l'origine attaque (pas d'IP attaquant visible)
  - Combine avec IP spoofing
```

DDoS Mitigation Strategies

Stratégie	Description	Niveau
Over-provisioning	Bande passante > pic attendu	Infrastructure
Rate limiting	Limite requêtes/sec	Application
Géo-blocking	Bloquer pays non pertinents	Network
Anycast	Distribuer trafic géographiquement	Network
Scrubbing centers	Filtrer trafic malicieux (Cloudflare, Akamai)	Vendor
WAF	Web Application Firewall	Application

Attack Lifecycle & Techniques

8-Phase Attack Lifecycle

Phase	Objectif	Techniques	Durée Typique
1. Reconnaissance	Collecte information	OSINT, Google dorks, Shodan, LinkedIn	Heures - Semaines
2. Scanning	Identifier cibles actives	Nmap, Nessus, port scan, OS fingerprint	Minutes - Heures

3. Vulnerability Analysis	Trouver vulnérabilités	CVE search, exploit-db, fuzzing	Heures - Jours
4. Intrusion	Accès initial	Exploit, phishing, credential stuffing	Minutes - Heures
5. Privilege Escalation	Obtenir permissions élevées	Kernel exploits, sudo abuse, token theft	Minutes - Heures
6. Compromise	Accomplir objectif	Data exfiltration, deploy ransomware	Minutes - Jours
7. Persistence	Maintenir accès	Backdoor, scheduled tasks, rootkit	Minutes - Heures
8. Cleanup	Effacer traces	Clear logs, timestomp, remove artifacts	Minutes - Heures

Password Attacks

Type	Mécanisme	Vitesse	Défense
Brute Force	Tester toutes combinaisons	Très lent (8-char = ans)	Long password, rate limiting
Dictionary	Tester mots communs	Rapide (millions/sec)	Reject common passwords
Hybrid	Dictionary + variations (Pass123!)	Rapide	Complexity requirements
Credential Stuffing	Réutiliser breached credentials	Scalable (botnet)	2FA, breach monitoring
Rainbow Tables	Pre-computed hashes	Instant lookup	Salt hashes (defeats tables)
Phishing	Social engineering	High success rate	User training, 2FA

Hash Algorithm Security:

Algorithm	Status	Speed	Salt?	Use Case
MD5	❌ Cassé	Très rapide	❌	Checksum only (NOT passwords)
SHA-1	❌ Cassé (collision)	Rapide	❌	Legacy only

SHA-256	✅ Bon	Rapide	✅	General hashing
bcrypt	✅ Excellent	Lent (intentionnel)	✅	**Password storage**
Argon2	✅ Excellent	Lent (GPU-resistant)	✅	**Modern password storage**

Recommendation: Use **bcrypt** or **Argon2** for password hashing (NOT SHA-256 or MD5).

Application Security

SQL Injection

Vulnerable Code:

```
# ❌ VULNERABLE (string concatenation)
query = "SELECT * FROM users WHERE username = '" + user_input + "'"
cursor.execute(query)
```

Attack:

```
Input: admin' OR '1'='1
Query becomes: SELECT * FROM users WHERE username = 'admin' OR '1'='1'
Result: Returns ALL users (authentication bypass)
```

Secure Code:

```
# ✅ SECURE (parameterized query)
query = "SELECT * FROM users WHERE username = ?"
cursor.execute(query, (user_input,))
```

SQLi Types:

Type	Mécanisme	Détection
Classic (In-band)	Résultats dans réponse	Facile (error messages)
Blind Boolean	True/False différentiel	Lent (timing)
Blind Time-based	SLEEP() delays	Très lent
Out-of-band	DNS/HTTP exfiltration	Advanced

Defense:

- ✅ **Parameterized queries (Prepared statements)** — BEST
- ✅ **ORM** — Good (but can have SQLi if raw queries)
- ✅ **Input validation** — Defense-in-depth
- ✅ **Least privilege DB user** — Limit damage
- ⚠️ **WAF** — Bypass possible, not primary defense

Quick Reference Tables

Hashing Algorithms

Algorithm	Output Size	Status	Speed	Use Case
MD5	128 bits	❌ Cassé	Très rapide	Checksum only
SHA-1	160 bits	❌ Cassé (collision)	Rapide	Legacy Git
SHA-256	256 bits	✅ Secure	Rapide	General integrity
SHA-384	384 bits	✅ Secure	Rapide	High security
SHA-512	512 bits	✅ Secure	Rapide	Maximum security
RIPEMD-160	160 bits	✅ Secure	Rapide	Bitcoin addresses
Whirlpool	512 bits	✅ Secure	Lent	High security
bcrypt	Variable	✅ Excellent	Lent (intentional)	**Passwords**
Argon2	Variable	✅ Excellent	Lent (GPU-resistant)	**Modern passwords**

Hash Properties:

- **Fonction à sens unique:** Impossible calculer input depuis hash
- **Déterministe:** Même input → même hash
- **Effet avalanche:** 1 bit change → 50% hash change
- **Collision résistance:** Impossible trouver deux inputs avec même hash

Port Numbers (Common Services)

Port	Service	Protocol	Use
20/21	FTP	TCP	File transfer (insecure)
22	SSH	TCP	Secure shell

23	Telnet	TCP	Remote login (insecure)
25	SMTP	TCP	Email sending
53	DNS	UDP/TCP	Domain resolution
80	HTTP	TCP	Web (unencrypted)
110	POP3	TCP	Email retrieval
143	IMAP	TCP	Email access
443	HTTPS	TCP	Web (encrypted)
3306	MySQL	TCP	Database
3389	RDP	TCP	Windows remote desktop
5432	PostgreSQL	TCP	Database

Secure Protocols vs Insecure

Insecure	Secure	Improvement
HTTP (80)	HTTPS (443)	TLS encryption
FTP (21)	SFTP (22) / FTPS (990)	SSH / TLS encryption
Telnet (23)	SSH (22)	Encryption + auth
SMTP (25)	SMTPS (465/587)	TLS encryption
POP3 (110)	POP3S (995)	TLS encryption
IMAP (143)	IMAPS (993)	TLS encryption

CVE Risk Scoring (CVSS)

Score	Severity	Action
0.0	None	No action
0.1-3.9	Low	Monitor, schedule patch
4.0-6.9	Medium	Patch within 30 days
7.0-8.9	High	Patch within 7 days

9.0-10.0	Critical	**Patch immediately** (emergency)

Exam Strategy Tips

Time Management

```
3h exam = 180 minutes

Stratégie:
  1. Scan complet (5 min): Identifier questions faciles/difficiles
  2. Questions faciles d'abord (60 min): Accumuler points rapides
  3. Questions moyennes (60 min): Creuser concepts
  4. Questions difficiles (45 min): Résoudre complexes
  5. Révision (10 min): Vérifier calculs, termes français/anglais
```

Common Traps

```
❌ Confondre:
  - Confidentialité vs Intégrité
  - Chiffrement symétrique vs asymétrique
  - Hash vs MAC
  - DV vs OV vs EV
  - CRL vs OCSP

✅ Vérifier:
  - Unités (bits vs bytes: 256 bits = 32 bytes)
  - Formules (R = P × I, pas P + I)
  - Terminologie (français vs anglais)
  - Exemples concrets (RSA: clé publique chiffrer, clé privée déchiffrer)
```

Key Formulas & Calculations

RSA Key Generation:

```
n = p × q
φ(n) = (p - 1) × (q - 1)
gcd(e, φ(n)) = 1
(e × d) mod φ(n) = 1
```

RSA Encryption/Decryption:

```
C = M^e mod n
M = C^d mod n
```

Risk:

```
R = P × I
```

Amplification Factor:

```
Factor = Response_size / Request_size
```

Memory Aids (Mnemonics)

CIA Triad

```
"Confidentiality Integrity Availability"
→ "Cats Ignore Alarms" (memorize C-I-A order)

Confidentialité: SECRET (chiffrement)
Intégrité: EXACTITUDE (hash)
Disponibilité: ACCESSIBLE (redondance)
```

Password Hash Ranking (Weakest → Strongest)

```
MD5 < SHA-1 < SHA-256 < bcrypt < Argon2

Memorize: "My Silly Algorithm Became Awesome"
```

Certificate Classes (1 → 5)

```
1 (Email) < 2 (Individual) < 3 (DV) < 4 (OV) < 5 (EV)

Memorize: "Every Individual Deserves Organizational Excellence"
```

PKI Components

```
CA, RA, CRL, CR, End Entity, Relying Party

Memorize: "Cats Rarely Catch Red Elephants Reliably"
```

Attack Lifecycle (8 Phases)

```
Reconnaissance → Scanning → Vuln Analysis → Intrusion → Priv Esc → Compromise →
Persistence → Cleanup

Memorize: "Really Smart Vultures Invade Private Compounds Persistently Carefully"
```

Last-Minute Review Checklist

Must Know (High Probability)

- [ ] **CIA Triad:** Definitions + examples (C=chiffrement, I=hash, D=redondance)
- [ ] **Risk formula:** R = P × I (avec exemple calcul)
- [ ] **Governance axes:** Stratégique, Tactique, Opérationnel
- [ ] **Symmetric vs Asymmetric:** Différences clé
- [ ] **AES vs DES vs 3DES:** Status, key sizes
- [ ] **Block cipher modes:** ECB (JAMAIS), CBC (bon+MAC), GCM (meilleur)
- [ ] **RSA key generation:** p, q, n, ϕ(n), e, d (5 étapes)
- [ ] **Digital signature:** 5 steps (résumé → sign → send → hash → verify)
- [ ] **Certificate classes:** 1-5 (DV, OV, EV)
- [ ] **PKI components:** CA, RA, CRL, CR
- [ ] **PKCS standards:** #1 (RSA), #7 (CMS), #10 (CSR), #12 (.p12)
- [ ] **Trust models:** Directe, Tiers, Hiérarchique, Distribuée, Passerelle
- [ ] **DoS/DDoS:** SYN flood, amplification (DNS 50×, NTP 556×, Memcached 51,000×)
- [ ] **Attack lifecycle:** 8 phases (Recon → ... → Cleanup)
- [ ] **Password attacks:** Brute force, dictionary, credential stuffing, rainbow tables
- [ ] **SQL injection:** Prevention (parameterized queries)
- [ ] **Hash algorithms:** MD5/SHA-1 (cassé), SHA-256 (bon), bcrypt/Argon2 (passwords)

French/English Terms (Bilingual)

Français	English
Chiffrement	Encryption

Déchiffrement	Decryption
Clé	Key
Clé publique	Public key
Clé privée	Private key
Certificat numérique	Digital certificate
Autorité de Certification	Certificate Authority (CA)
Signature numérique	Digital signature
Résumé	Hash / Digest
Confiance	Trust
Intégrité	Integrity
Confidentialité	Confidentiality
Disponibilité	Availability
Menace	Threat
Vulnérabilité	Vulnerability
Risque	Risk

Final Notes

Exam Focus Areas (Based on Course Materials):

1. ✅ **Cryptography:** 40% (symmetric, asymmetric, hash, certificates, PKI)
2. ✅ **Security Fundamentals:** 20% (CIA, risk, governance)
3. ✅ **Network Security:** 15% (DoS/DDoS, protocols)
4. ✅ **Attacks:** 15% (lifecycle, password attacks, SQLi)
5. ✅ **Application Security:** 10% (SQLi, secure coding)

Best Practices for Exam:

- Read questions carefully (watch for "SAUF" / "EXCEPT")
- Draw diagrams for complex scenarios (certificate chains, attack flows)
- Show calculations for numerical questions (partial credit)
- Use French terminology correctly (bilingual awareness)

- If unsure, eliminate obviously wrong answers first
- Budget time: Don't spend 30min on one 5-point question

Good luck! Bonne chance! 🎓

Document Version: 1.0
Last Updated: April 27, 2026
Author: PtiCalin (Charlie)
Course: IFT2830 - H26
Status: ✅ Ready for Final Exam